

THRIVE AFRICA

CYBERSECURITY INTERNSHIP

WEEK 5

Security Governance &
Policy Development

Metasploitable 2 | Group 8 | April 2026

Document Reference:	GRP8-WEEK5-GOV-2026
Classification:	Internal – Internship Use Only
Target System:	Metasploitable 2 (Simulated Corporate Environment)
Version:	1.0 – Initial Release
Date:	April 2026
Prepared by:	Group 8, Thrive Africa Cybersecurity Internship

CONFIDENTIAL – For Training & Assessment Purposes Only

SECTION 1: INTRODUCTION & GOVERNANCE OVERVIEW

1. Introduction

This document constitutes the Week 5 deliverable for Group 8 of the Thrive Africa Cybersecurity Internship programme. It builds directly on the vulnerability assessment (Week 3) and risk analysis (Week 4) conducted against the Metasploitable 2 target system, translating technical findings into enforceable security governance artefacts.

Security governance is the framework through which an organisation ensures that its information security strategies are aligned with business objectives, regulatory requirements, and risk tolerance. Without governance, even technically sound security controls remain uncoordinated and unenforceable. This document addresses that gap by establishing clear roles, responsibilities, a governance structure, and a suite of security policies derived from the specific risks identified during earlier assessment phases.

1.1 Purpose

The purpose of this document is to:

- Define security roles and responsibilities for personnel interacting with organisational systems
- Establish a governance structure that ensures accountability and oversight
- Develop enforceable security policies that directly address the 13 vulnerabilities identified across 24 open ports on Metasploitable 2
- Provide practical guidance that real employees can understand and follow

1.2 Scope

This governance framework applies to all systems, users, and processes within the simulated corporate environment represented by the Metasploitable 2 target. The policies contained herein apply to:

- All employees, contractors, interns, and third-party users with access to organisational IT systems
- All hardware, software, data, and network infrastructure under organisational control
- All physical and virtual environments connected to or interacting with organisational systems

1.3 Reference to Week 4 Risk Register

This governance framework is grounded in the risk findings of Week 4. The table below summarises the 13 identified vulnerabilities that the policies herein are designed to address:

Vulnerability	CVE	Port	CVSS	Risk Level	Priority
vsftpd 2.3.4 backdoor	CVE-2011-2523	21/tcp	9.8	Critical	P1
Samba 3.x RCE	CVE-2007-2447	139/445	10.0	Critical	P1
UnrealIRCd 3.2.8.1 backdoor	CVE-2010-2075	6667/tcp	9.8	Critical	P1
distccd RCE	CVE-2004-2687	3632/tcp	9.3	Critical	P1

Ingreslock root shell	N/A (backdoor)	1524/tcp	10.0	Critical	P1
Linux telnetd (plaintext)	CVE-2022-39028	23/tcp	7.5	High	P2
MySQL 5.0.51a overflow	CVE-2008-0226	3306/tcp	7.5	High	P2
VNC authentication bypass	CVE-2006-2369	5900/tcp	7.5	High	P2
ProFTPD 1.3.1 CSRF	CVE-2008-4242	2121/tcp	6.8	Medium	P3
NFS unauthorised file access	CVE-2006-3005	2049/tcp	5.0	Medium	P3
PostgreSQL 8.3.0 DoS	CVE-2009-0922	5432/tcp	4.0	Medium	P3
OpenSSH 4.7p1 CBC weakness	CVE-2008-5161	22/tcp	2.6	Low	P4

SECTION 2: SECURITY ROLES & RESPONSIBILITIES

2. Security Roles & Responsibilities

Clear role definitions are foundational to effective security governance. When every person in the organisation knows what they are responsible for — and what they are accountable to — security controls become consistent and enforceable. The following roles have been defined in alignment with ISO/IEC 27001 principles and the specific risk landscape of the assessed environment.

2.1 Role Definitions

ROLE 1 – Information Security Officer (ISO)

Reports To	Chief Executive Officer / Board
Accountability	Overall security posture and governance programme
Key Responsibilities	•Own and maintain all security policies; review annually or after significant incidents •Define risk tolerance thresholds and ensure risks from the register are tracked to closure •Ensure regulatory and legal compliance (data protection, cyber insurance requirements) •Approve exceptions to security policy where operationally necessary •Lead post-incident reviews and ensure lessons learned are incorporated into policy updates •Liaise with external auditors, regulators, and third-party security providers
Risk Context	Given the Critical-risk vulnerabilities (CVSS 9.3–10.0) on ports 21, 139/445, 1524, and 6667, the ISO must champion immediate remediation and ensure budget and resource allocation are not delayed.

ROLE 2 – System Administrator

Reports To	Information Security Officer
Accountability	Security and operational integrity of all systems, servers, and network infrastructure
Key Responsibilities	•Implement and maintain all technical controls: firewall rules, patch management, access controls, and service hardening •Disable or restrict unnecessary services (Telnet, NFS, VNC, FTP) in line with the Least Privilege principle •Apply security patches within defined SLAs: Critical within 24 hours, High within 7 days, Medium within 30 days •Manage user accounts: enforce MFA, disable dormant accounts, and rotate service account credentials quarterly •Monitor system logs and alert on anomalous behaviour such as repeated authentication failures or root-level commands •Conduct monthly vulnerability scans and report results to the ISO within 5 business days •Maintain configuration baselines and change documentation for all managed systems
Risk Context	The System Administrator is the first line of technical defence. Immediate actions include: closing port 1524, replacing Telnet with SSH, restricting MySQL to localhost, and disabling NFS public exports.

ROLE 3 – Data Custodian

Reports To	Information Security Officer
Accountability	Day-to-day stewardship of data assets including classification, storage, backup, and access management
Key Responsibilities	•Classify all data assets according to the organisation's data classification scheme (Public, Internal, Confidential, Restricted) •Maintain and test data backup procedures; ensure recovery is tested at least quarterly •Ensure data is encrypted at rest and in transit for Confidential and Restricted classifications •Audit database access logs monthly; escalate anomalies to the ISO within 24 hours •Approve and document all requests to access or share Confidential data, ensuring business justification is recorded
Risk Context	With MySQL 5.0.51a exposed on port 3306 alongside phpMyAdmin on port 80, the Data Custodian must enforce database access controls and ensure sensitive data is not accessible to unauthenticated users.

ROLE 4 – Information Asset Owner

Reports To	Senior Management / Business Unit Head
Accountability	Business value and risk decisions for specific information assets assigned to their portfolio
Key Responsibilities	•Formally own and accept residual risk for assigned information assets •Approve access requests to their assets and ensure access is reviewed semi-annually •Communicate the sensitivity and handling requirements of their assets to all users with access •Ensure that third-party or vendor access to their assets is governed by written agreements

ROLE 5 – General User (Employee / Contractor / Intern)

Reports To	Line Manager / Departmental Head
Accountability	Responsible use of organisational systems and compliance with all applicable security policies
Key Responsibilities	•Comply with all security policies, standards, and procedures as communicated by the ISO •Report suspected security incidents, phishing attempts, or unusual system behaviour immediately to the ISO or helpdesk •Protect assigned credentials: never share passwords, enable MFA, and lock workstations when away •Complete mandatory security awareness training within 30 days of joining and annually thereafter •Refrain from installing unauthorised software or connecting personal devices to corporate networks without approval

SECTION 3: GOVERNANCE STRUCTURE

3. Governance Structure

The governance structure defines how security decisions are made, who has authority over what, and how information flows between roles. This structure ensures that risks are escalated appropriately, policies are enforced consistently, and accountability is clear at every level of the organisation.

3.1 Governance Hierarchy



3.2 Decision Rights Matrix

The matrix below clarifies who has authority to approve, implement, or simply be informed about key security decisions:

Decision Area	Board	ISO	Sys Admin	Custodian	User
Approve security budget	Approve	Recommend	—	—	—
Define/update security policies	Ratify	Own	Input	Input	Comply
Apply system patches	—	Oversee	Implement	—	—
Approve data access requests	—	Exceptions	Provision	Approve	Request
Declare a security incident	Notify	Declare	Escalate	Escalate	Report
Grant policy exceptions	—	Approve	—	—	Request
Conduct vulnerability scans	—	Commission	Execute	—	—
Report potential incidents	—	Receive	Receive	—	Duty

3.3 Escalation Path

All security matters must follow the escalation path below. Skipping levels is only permitted in declared emergencies (e.g., active intrusion detected):

- Step 1: General User detects anomaly (suspicious login, unknown file, system slowdown) ! Reports to their Line Manager AND the System Administrator within 1 hour

- Step 2: System Administrator assesses the report. If confirmed or suspected breach ! Notifies the ISO immediately (within 30 minutes)
- Step 3: ISO evaluates severity. If Critical or High ! Notifies the Board and initiates the Incident Response Plan within 2 hours
- Step 4: If a data breach affecting personal or regulated data is confirmed ! ISO notifies the relevant data protection authority within the legally required window (e.g., 72 hours under GDPR equivalents)
- Step 5: Post-incident, the ISO leads a lessons-learned review and updates risk register and policies within 30 days

POLICY 1: INFORMATION SECURITY POLICY (COMPULSORY)

4. Information Security Policy

Document Reference	Policy Owner	Version
POL-001-ISP	Information Security Officer	v1.0
Applies To	Effective Date	Review Date
All employees, contractors, interns, third parties	April 2026	April 2027
Linked Risks	Classification	
All 13 CVEs from the Week 4 Risk Register CVSS range 2.6–10.0	INTERNAL	

4.1 Purpose

This Information Security Policy establishes the organisation's commitment to protecting the confidentiality, integrity, and availability of all information assets. It sets the overarching principles that govern all other security policies, standards, and procedures. Every person who accesses organisational systems or data is bound by this policy.

4.2 Policy Statement

The organisation is committed to:

- Protecting all information assets from unauthorised access, disclosure, modification, and destruction
- Ensuring business continuity by maintaining the availability of critical systems and data
- Complying with all applicable laws, regulations, and contractual obligations relating to information security
- Continuously improving the organisation's security posture through regular risk assessments, audits, and training
- Holding all personnel accountable for their role in maintaining information security

4.3 Guiding Principles

Principle	What It Means in Practice
Least Privilege	Every user, system, and service is granted only the minimum access required to perform its function. Root or administrative access is never used for routine tasks.
Defence in Depth	Security controls are layered. No single control is relied upon. Firewalls, access controls, encryption, monitoring, and policies work together to reduce overall risk.
Need to Know	Access to information is granted based on verified business need, not simply on seniority or convenience. Access is revoked immediately when the need ceases.
Accountability	All actions on organisational systems are logged and attributable to a named individual. Shared or anonymous accounts are prohibited.

Risk-Based Approach	Security controls are proportionate to the risk they address. Resources are prioritised toward the highest-risk vulnerabilities first (see Week 4 Priority 1 list).
Transparency	Security incidents, near misses, and policy breaches are reported honestly and without fear of blame, so lessons can be learned and controls improved.

4.4 Roles and Obligations

Senior Management is responsible for allocating sufficient resources — budget, staff, and time — to maintain an effective security programme. The ISO is responsible for implementing and overseeing this programme. All staff are responsible for complying with security policies and reporting incidents without delay. Non-compliance may result in disciplinary action up to and including termination of employment or contract.

4.5 Risk Register Integration

The organisation maintains a living risk register, updated at minimum quarterly and after every significant security event. The register is the primary input for security investment decisions. As of April 2026, five Critical-risk vulnerabilities (CVSS ≥ 9.0) are on record and must be addressed within the timelines defined in the Access Control and related policies.

4.6 Compliance and Exceptions

Compliance with this policy is mandatory. Where compliance is technically infeasible or would cause unacceptable operational disruption, a formal exception request must be submitted to the ISO. Exceptions are time-bound (maximum 90 days), require documented compensating controls, and must be reviewed before renewal.

4.7 Policy Review

This policy is reviewed annually by the ISO and updated following any significant change in technology, business operations, or threat landscape. All personnel are notified of updates within 5 business days of publication and must acknowledge acceptance within 10 business days.

POLICY 2: ACCESS CONTROL POLICY

5. Access Control Policy

Document Reference	Policy Owner	Version
POL-002-ACP	Information Security Officer / System Administrator	v1.0
Applies To	Effective Date	Review Date
All employees, contractors, interns, administrators, third parties	April 2026	April 2027
Linked Risks	Classification	
CVE-2006-2369 (VNC bypass) CVE-2011-2523 (vsftpd) CVE-2010-2075 (UnrealIRCd) CVE-2008-0226 (MySQL) Ingreslock root shell (port 1524) CVE-2022-39028 (Telnet)	INTERNAL	

5.1 Purpose

This policy governs how access to organisational systems, applications, data, and networks is granted, managed, monitored, and removed. It exists to prevent unauthorised access – a risk demonstrated by multiple vulnerabilities in the assessed environment, including VNC authentication bypass (CVE-2006-2369), the Ingreslock root shell backdoor on port 1524, and Telnet transmitting credentials in plaintext.

5.2 Scope

This policy applies to all systems, services, databases, and network resources owned or managed by the organisation, including but not limited to: web servers, database servers (MySQL, PostgreSQL), remote access tools (SSH, VNC), file transfer services (FTP, NFS), and any third-party hosted services accessed with organisational credentials.

5.3 User Account Management

5.3.1 Account Provisioning

- Every user must have a unique, individually assigned account. Generic, shared, or anonymous accounts are strictly prohibited.
- Access is provisioned using a formal request process. The request must include: the user's name and role, the specific systems and data they need access to, the business justification, and the approval of the relevant Asset Owner and System Administrator.
- New accounts are provisioned on the principle of minimum necessary access. Additional permissions must be separately requested and justified.

- Accounts for contractors, interns, and third parties are time-limited to their engagement period and must be automatically disabled on the last working day of the engagement.

5.3.2 Authentication Requirements

- All accounts with access to Confidential or Restricted data must use Multi-Factor Authentication (MFA). MFA is mandatory for all remote access.
- Telnet (port 23) is prohibited for all use. SSH must be used for all remote terminal access. This directly addresses CVE-2022-39028 and the inherent plaintext risk of Telnet.
- VNC (port 5900) must never be exposed directly to a network without authentication. VNC 3.3 is prohibited. If VNC must be used, it must be tunnelled over an authenticated SSH session and use VNC-level passwords of at least 16 characters.
- Default passwords on all services (including FTP, database, web management) must be changed prior to deployment. No service may operate with factory-default or blank credentials.

5.3.3 Privileged Access

- Root, Administrator, and equivalent privileged accounts may only be used for specific administrative tasks. They must not be used for day-to-day operations such as email, web browsing, or file management.
- All use of privileged accounts must be logged. Logs are reviewed weekly by the System Administrator and monthly by the ISO.
- Port 1524 (Ingreslock) must be permanently blocked at the firewall level and the service disabled at the OS level. Under no circumstances is a service that grants unauthenticated root shell access permitted on any organisational system.
- The distccd service (port 3632) must be restricted to trusted internal hosts via firewall rules. Remote code execution via compiler daemons is not an acceptable operational risk.

5.4 Network Access and Port Management

The following rules govern network-level access control:

Port / Service	Default Status	Permitted Use	Control Required
1524 (Ingreslock)	BLOCKED	None	Block at firewall; disable service; remove from /etc/inetd.conf
23 (Telnet)	DISABLED	None – use SSH	Disable telnetd; block port at firewall; enforce SSH-only remote access
5900 (VNC)	RESTRICTED	SSH tunnel only	Block direct VNC; require SSH tunnel; enforce VNC authentication; upgrade from VNC 3.3
3306 (MySQL)	LOCALHOST ONLY	Internal apps only	Bind to 127.0.0.1; disable remote root login; enforce strong DB passwords
21 (vsftpd)	UPGRADE/REPLACE	SFTP preferred	Upgrade to non-backdoored version or replace with SFTP; disable anonymous FTP
2049 (NFS)	RESTRICTED	Trusted hosts only	Restrict exports to specific IP ranges; upgrade to NFSv4 with Kerberos; use VPN
22 (SSH)	PERMITTED	Authorised users	Disable CBC cipher modes in sshd_config; enforce key-based auth; disable root SSH login
80/443 (HTTP/S)	MONITORED	Web traffic only	Upgrade Apache from 2.2.8 (EOL); enforce

			HTTPS: restrict phpMvAdmin to localhost
--	--	--	---

5.5 Access Review and Revocation

- Access rights for all users are reviewed semi-annually. The Data Custodian performs the review; the Asset Owner approves the results.
- Access is revoked immediately upon: termination of employment, end of contractor engagement, change of role (when access is no longer required), or confirmed security incident involving that account.
- The System Administrator must disable accounts within 4 business hours of receiving an authorised revocation request.
- All changes to access rights – grants, modifications, and revocations – are logged and retained for 12 months minimum.

5.6 Enforcement

Violations of this policy – including attempts to circumvent access controls, use of prohibited protocols (Telnet, unencrypted FTP), or accessing systems without authorisation – constitute a serious disciplinary matter. Depending on severity, consequences range from formal warnings to termination and, where applicable, referral for criminal investigation.

POLICY 3: PASSWORD POLICY

6. Password Policy

Document Reference	Policy Owner	Version
POL-003-PWD	Information Security Officer	v1.0
Applies To	Effective Date	Review Date
All users with organisational accounts (employees, contractors, admins, interns)	April 2026	April 2027
Linked Risks	Classification	
CVE-2022-39028 (Telnet plaintext credential harvest) CVE-2006-2369 (VNC no-auth) CVE-2008-0226 (MySQL weak auth) CVE-2011-2523 (vsftpd backdoor – default cred risk)	INTERNAL	

6.1 Purpose

Passwords are the first barrier between an attacker and organisational systems. The Week 4 assessment revealed that several services on the Metasploitable 2 target either had no authentication (VNC port 5900), transmitted credentials in plaintext (Telnet port 23), or used default credentials (MySQL, vsftpd). This policy mandates strong, unique, and properly protected passwords across all systems to reduce the risk of credential compromise.

6.2 Password Requirements

Account Type	Minimum Requirements	Additional Controls
General User Account	14 characters Upper + lower + number + symbol No dictionary words No name or birthday	MFA required Change every 180 days No reuse of last 12 passwords
Administrative / Privileged Account	20 characters All character classes Machine-generated preferred No personal information	MFA required Change every 90 days Stored in password manager Logged on every use
Service / Application Account	32 characters Randomly generated No human-memorable patterns	Never expires but rotated after any personnel change Stored in vault Never hardcoded in source code
Database Accounts (MySQL, PostgreSQL)	20+ characters Randomly generated Default passwords changed before first use	Remote root login disabled Bind to localhost where possible Audited monthly

VNC / Remote Desktop	16+ characters VNC-level password as minimum SSH tunnel required in addition	VNC 3.3 (no-auth mode) prohibited Never expose without SSH tunnel
----------------------	--	--

6.3 Password Protection Rules

All users must adhere to the following rules for protecting their credentials:

- Never share a password with anyone – including colleagues, managers, or IT support staff. IT staff will never ask for your password.
- Never write passwords on paper, sticky notes, or in unencrypted files (e.g., plain text files, spreadsheets, email).
- Use a password manager approved by the organisation for storing and generating credentials.
- Never use the same password for organisational accounts as for personal accounts (email, social media, banking).
- If you suspect your password has been compromised, change it immediately and report the incident to the ISO within 1 hour.
- Passwords must not be transmitted over plaintext protocols. Telnet (port 23), unencrypted FTP, and HTTP-based admin panels are prohibited for credential use.

6.4 Default and Hardcoded Passwords

Default passwords on all services, devices, and applications must be changed before they are connected to any organisational network or made accessible to users. This includes:

- Operating system default accounts (e.g., MySQL's root with no password, vsftpd anonymous access)
- Network device default credentials (routers, switches, access points)
- Web management interfaces (phpMyAdmin, admin consoles)
- Any application where a vendor-supplied default credential exists

Hardcoding passwords in source code, configuration files, or scripts is strictly prohibited. Credentials for application service accounts must be stored in a secrets management vault and injected at runtime.

6.5 Multi-Factor Authentication (MFA)

Password-only authentication is insufficient for high-risk systems. MFA is mandatory for:

- All remote access connections (SSH, VPN)
- All privileged and administrative accounts
- Any system storing Confidential or Restricted data
- Web-based management interfaces (phpMyAdmin, cPanel equivalents)

Acceptable MFA methods include: time-based one-time passwords (TOTP via authenticator apps), hardware security keys (FIDO2/WebAuthn), or push-based mobile authentication. SMS-based OTP is accepted only as a fallback and not as a primary second factor.

6.6 Enforcement and Monitoring

Password policy compliance is technically enforced through system configuration where possible (password complexity rules, history enforcement, account lockout). Accounts are locked after 5 consecutive failed login

attempts; lockout requires manual review and reset by the System Administrator. Lockout events are logged, investigated for patterns, and reported to the ISO monthly.

POLICY 4: INCIDENT REPORTING POLICY

7. Incident Reporting Policy

Document Reference	Policy Owner	Version
POL-004-IRP	Information Security Officer	v1.0
Applies To	Effective Date	Review Date
All personnel Applicable to all systems and data assets	April 2026	April 2027
Linked Risks	Classification	
All Critical/High vulnerabilities: vsftpd, Samba, UnrealIRCd, distccd, Ingreslock, Telnet, MySQL, VNC – any of which could be exploited to trigger an incident requiring formal reporting	INTERNAL	

7.1 Purpose

Security incidents are inevitable in any environment. What distinguishes resilient organisations is how quickly and effectively they detect, report, and respond to them. The environment assessed in Week 3 and 4 contains multiple backdoors and remotely exploitable vulnerabilities that, if triggered, would constitute serious security incidents. This policy ensures that all personnel know exactly what to report, to whom, and by when.

7.2 What Is a Security Incident?

A security incident is any event – or suspected event – that threatens the confidentiality, integrity, or availability of organisational information or systems. Examples include:

Category	Examples
Unauthorised Access	Unknown user logged in; root shell obtained; admin account used outside business hours
Malware / Ransomware	Files encrypted unexpectedly; suspicious processes; antivirus alert triggered
Data Breach	Customer records accessed without authorisation; database dumped; credentials exposed
Denial of Service	System unavailable; PostgreSQL crash; network flooded (ref. CVE-2009-0922)
Phishing / Social Engineering	Suspicious email requesting credentials; caller claiming to be IT support; unexpected password reset

Policy Violation	User found using Telnet; shared accounts discovered; unpatched service reactivated
Category	Examples
Unauthorised Access	Unknown user logged in; root shell obtained; admin account used outside business hours
Malware / Ransomware	Files encrypted unexpectedly; suspicious processes; antivirus alert triggered
Data Breach	Customer records accessed without authorisation; database dumped; credentials exposed
Denial of Service	System unavailable; PostgreSQL crash; network flooded (ref. CVE-2009-0922)
Phishing / Social Engineering	Suspicious email requesting credentials; caller claiming to be IT support; unexpected password reset
Policy Violation	User found using Telnet; shared accounts discovered; unpatched service reactivated
Backdoor / Exploit Activity	Connections to port 1524 or 6667; unusual outbound traffic; Metasploit-type payloads detected

7.3 Incident Severity Levels

Severity	Description	Response Time	Examples from Risk Register
CRITICAL	Active exploit; confirmed breach; ransomware; total system compromise	Immediate – ISO notified in 15 min	Ingreslock root shell triggered vsftpd backdoor exploited Samba RCE active
HIGH	Suspected breach; credential compromise; data exfiltration in progress	Within 1 hour of detection	VNC accessed without auth MySQL data dump detected Telnet credentials sniffed
MEDIUM	Policy violation; suspicious activity; potential vulnerability being probed	Within 4 hours of detection	NFS export accessed by unknown host PostgreSQL crash event ProFTPD CSRF attempt
LOW	Near miss; informational alert; minor policy deviation with no impact	Within 24 hours via standard report	Repeated SSH login failures (possible scan) Weak cipher mode flagged in audit

7.4 How to Report an Incident

Reporting an incident is straightforward. Follow these steps:

- Step 1 – Stop and Observe: Do not touch the affected system, close applications, or attempt to fix the problem yourself. Preserve evidence.
- Step 2 – Record What You Saw: Note the time, what you observed, which system was affected, and what you were doing when you noticed it. Screenshots are valuable if safe to take.
- Step 3 – Report Immediately: Contact the ISO or System Administrator using the designated incident reporting channel (Slack #security-incidents, direct call, or email security@organisation.com). For Critical incidents, use a phone call – do not rely on email alone.
- Step 4 – Complete the Incident Report Form: Within 2 hours of initial notification, complete the formal

Incident Report Form. This includes: incident description, affected systems, perceived impact, timeline, and any immediate actions taken.

- Step 5 – Follow Instructions: Do not discuss the incident publicly, on social media, or with unauthorised colleagues. Wait for guidance from the ISO on next steps.

7.5 What Happens After You Report

- The ISO acknowledges receipt within 30 minutes for Critical/High incidents, 4 hours for Medium, and 24 hours for Low.
- The System Administrator isolates affected systems where necessary to prevent further damage.
- A post-incident review is conducted within 30 days and findings are presented to senior management.
- The risk register is updated to reflect the incident and any newly identified vulnerabilities.
- Policy or control gaps identified during the review are remediated within the next policy review cycle.

7.6 No-Blame Reporting Culture

The organisation actively promotes a no-blame approach to incident reporting. Personnel who report incidents promptly are contributing to the security of the organisation. Disciplinary action is reserved for deliberate policy violations or gross negligence – not for honest mistakes or good-faith reporting. Failure to report a known incident, however, is itself a disciplinary matter.

POLICY 5: ACCEPTABLE USE POLICY

8. Acceptable Use Policy

Document Reference	Policy Owner	Version
POL-005-AUP	Information Security Officer	v1.0
Applies To	Effective Date	Review Date
All employees, contractors, interns, and any third party using organisational systems	April 2026	April 2027
Linked Risks	Classification	
CVE-2010-2075 (UnrealIRCd – IRC misuse vector) CVE-2004-2687 (distccd – developer tool misuse) CVE-2006-3005 (NFS – unauthorised file access) CVE-2022-39028 (Telnet – prohibited protocol)	INTERNAL	

8.1 Purpose

Organisational IT systems are provided to enable employees to carry out legitimate business functions. Misuse of these systems – whether intentional or through negligence – can create security vulnerabilities, legal liability, and reputational harm. This policy defines what constitutes acceptable and unacceptable use of all organisational IT resources.

8.2 Acceptable Use – Permitted Activities

Organisational IT systems may be used for:

- Business-related communication, collaboration, and productivity
- Accessing data and applications required to perform assigned job functions
- Attending security awareness training, reviewing policy documentation, and completing compliance requirements
- Reasonable, limited personal use during personal time, provided it does not consume significant resources, create security risks, or violate any other provision of this policy

8.3 Unacceptable Use – Prohibited Activities

The following are strictly prohibited on all organisational systems:

Category	Prohibited Actions
Unauthorised Software	Installing software, tools, or services not approved by the System Administrator. This includes IRC clients (referencing UnrealIRCd CVE-2010-2075), peer-to-peer software, or penetration testing tools on production systems.
Prohibited Protocols	Using Telnet (port 23), unencrypted FTP, or any protocol that transmits credentials or sensitive data in plaintext. SSH is the mandatory alternative.
Circumventing Security	Attempting to bypass, disable, or alter any security control, firewall rule, access restriction, or monitoring tool. This includes attempting to access port 1524 (Ingreslock) or other backdoor services.
Unauthorised Data Access	Accessing, copying, or transferring data that you have not been explicitly authorised to access. This includes mounting NFS shares (port 2049) without documented authorisation.
Developer Tool Abuse	Using compiler daemons or development services (e.g., distccd on port 3632) for purposes other than their approved function. Such services must be restricted to trusted hosts only.
Sharing Credentials	Sharing login credentials with colleagues, contractors, or third parties. Each individual must use their own uniquely assigned account at all times.
Illegal Activity	Using organisational systems for any activity that is illegal under applicable law, including hacking third-party systems, distributing malware, copyright infringement, or accessing prohibited content.
Storing Sensitive Data Insecurely	Storing Confidential or Restricted data on unencrypted devices, personal cloud accounts, USB drives, or any location not approved for that data classification.

8.4 Monitoring and Privacy

Users should have no expectation of privacy when using organisational IT systems. The organisation reserves the right to monitor, log, and inspect any activity on its systems for security, compliance, and operational purposes. Monitoring is conducted proportionately and in accordance with applicable privacy law. Users are notified of monitoring through this policy – no further notice is required before monitoring takes place.

8.5 Personal Devices (BYOD)

Personal devices (laptops, phones, tablets) may only connect to organisational systems if they meet minimum security standards:

- Up-to-date operating system and security patches
- Installed and active endpoint protection (antivirus/EDR)
- Full-disk encryption enabled
- Enrolled in the organisation's Mobile Device Management (MDM) system and approved by the System Administrator

Personal devices that do not meet these requirements must not be connected to any organisational network, including Wi-Fi. Guest network access is available for personal use and does not have access to internal systems.

8.6 Consequences of Violations

Violations of this policy are treated as misconduct. Depending on the nature and severity of the violation,

consequences may include:

- Formal written warning
- Mandatory additional security awareness training
- Suspension or permanent revocation of system access
- Termination of employment or contract
- Referral to law enforcement or regulatory authorities where criminal conduct is suspected

SECTION 9: RISK-TO-POLICY TRACEABILITY MATRIX

9. Risk-to-Policy Traceability Matrix

The table below maps every vulnerability from the Week 4 risk register to the specific policies and controls introduced in this document. This traceability ensures that no identified risk has been left unaddressed at the governance level.

Vulnerability	Risk	Priority	ISP (POL-001)	Access Control (POL-002)	Other Policy
vsftpd 2.3.4 backdoor	Critical	P1	Section 4.3	Section 5.4 – Port 21 control	POL-003: Default password change
Samba 3.x RCE	Critical	P1	Section 4.5	Section 5.3.3 – Service restriction	POL-004: Incident response plan
UnrealIRCd backdoor	Critical	P1	Section 4.3	Section 5.4 – Port 6667	POL-005: Prohibited software
distccd RCE	Critical	P1	Section 4.3	Section 5.4 – Port 3632	POL-005: Dev tool abuse
Ingreslock root shell	Critical	P1	Section 4.3	Section 5.3.3 – Port 1524 BLOCKED	POL-004: Critical incident trigger
Apache 2.2.8 EOL	High	P2	Section 4.5	Section 5.4 – Port 80 control	POL-005: Unauthorised software
Linux telnetd (plaintext)	High	P2	Section 4.3	Section 5.3.2 – Telnet PROHIBITED	POL-003: No plaintext credentials POL-005: Prohibited protocols
MySQL buffer overflow	High	P2	Section 4.3	Section 5.4 – Port 3306 localhost	POL-003: DB password requirements
VNC auth bypass	High	P2	Section 4.3	Section 5.3.2 – VNC SSH tunnel	POL-003: VNC password requirements
ProFTPD CSRF	Medium	P3	Section 4.6	Section 5.4 – Port 2121	POL-004: Medium incident reporting
NFS unauthorised access	Medium	P3	Section 4.3	Section 5.4 – NFS restricted	POL-005: Unauthorised data access
PostgreSQL DoS	Medium	P3	Section 4.5	Section 5.4 – Port 5432	POL-004: Medium incident trigger
OpenSSH CBC weakness	Low	P4	Section 4.6	Section 5.4 – SSH hardening	POL-002: SSH cipher configuration

APPENDIX: DOCUMENT CONTROL & ACKNOWLEDGEMENT

10. Document Control

Version	Date	Author	Changes
v1.0	April 2026	Group 8 – Thrive Africa	Initial release – all five policies published

11. Staff Acknowledgement Record

All personnel bound by these policies must sign and return this section to HR within 10 business days of the document's effective date. A signed acknowledgement confirms the individual has read, understood, and agrees to comply with all policies contained in this document.

Full Name	Job Title	Date	Signature

12. Glossary

Term	Definition
CVSS	Common Vulnerability Scoring System – a standardised score (0–10) indicating the severity of a vulnerability.
CVE	Common Vulnerabilities and Exposures – a unique identifier for publicly known security vulnerabilities.
MFA	Multi-Factor Authentication – requiring two or more verification methods before granting access.
ISO (role)	Information Security Officer – the individual accountable for the organisation's security programme.
Least Privilege	A security principle requiring that users and systems have only the minimum permissions needed to function.
RCE	Remote Code Execution – a vulnerability class that allows an attacker to run commands on a target system remotely.
NFS	Network File System – a protocol for sharing files over a network; insecure if

	misconfigured.
VNC	Virtual Network Computing – a remote desktop protocol; older versions (3.3) lack proper authentication.
Backdoor	A covert method of bypassing normal authentication or access controls, often deliberately planted by an attacker or malicious software supply chain.
Defence in Depth	A layered security approach where multiple controls work together; failure of one does not mean total compromise.

— End of Document —

Group 8 | Thrive Africa Cybersecurity Internship | Week 5 | April 2026